



毕业设计 (论文) 开 题 报 告

题 目： 基于可信执行环境的密态病历信息系统

学 院：计算机与人工智能学院 专 业： 网络工程

班 级： 22 网工 2 班 学 号： 22211835217

姓 名： 唐 闫 琪 指导教师： 卢 益 彪

温州大学毕业设计（论文）开题报告

一、选题的背景与意义：

随着信息技术的飞速发展，电子病历（Electronic Medical Record, EMR）系统已成为现代医疗体系的核心。电子病历极大地提升了医疗服务的效率和质量，但同时也带来了前所未有的数据安全挑战。病历信息作为公民最敏感的隐私数据之一，一旦泄露，不仅会侵犯患者隐私权，还可能被用于欺诈、勒索等非法活动，造成严重的社会危害和经济损失。目前，主流的数据保护技术主要集中在“静态保护”（at-rest）和“传输中保护”（in-transit）。“静态保护”通过磁盘加密，防止物理设备丢失导致的数据泄露；“传输中保护”通过 SSL/TLS 等协议，确保数据在网络传输过程中不被窃听。然而，这两种技术都忽略了一个关键环节——“使用中保护”（in-use）。当数据被加载到内存中进行处理时（例如，医生查询病历、系统进行数据分析），它必须以明文形态存在。此时，数据完全暴露在操作系统（OS）、虚拟机管理器（VMM）甚至特权管理员的视野中。攻击者可以通过内存抓取、缓冲区溢出、恶意软件，或者利用系统漏洞、管理员后门等方式，直接从内存中窃取明文病历数据。传统的安全模型假设操作系统和管理员是可信的，但在云环境和复杂系统中，这一假设正变得越来越脆弱。因此，如何保护“使用中”的数据，防止来自特权软件和物理攻击的威胁，已成为信息安全领域的迫切需求。[9] 近年来，围绕可信执行环境（Trusted Execution Environment, TEE）及其在医疗数据保护与机密计算领域的应用，国内外学术界与产业界均开展了大量研究与工程实践。总体来看，研究可分为三条主线：TEE/SGX 平台与安全性分析、基于 TEE 的隐私保护/可搜索加密数据库与医疗数据共享方案、以及性能优化与实际部署（含机密计算在云/边缘/物联网场景的工程化实践）。国际研究现状：

TEE/SGX 的基础研究与评估：国际上对 Intel SGX 等 TEE 平台的体系结构、威胁模型、侧信道与微架构攻击都有深入分析，并产生大量调查类与评估类论文，为后续应用研究提供了理论与实验基础。[13] TEE 与密码学技术的组合：为了在可用性与安全性之间取得平衡，研究者提出将 TEE 与同态加密（HE）、安全多方计算（MPC）等密码学技术结合，以减少在 Enclave 内暴露的明文数据量或提高跨域协同计算的隐私保障能力。面向应用的系统与原型：在医疗、物联网、金融等敏感数据场景，国际上已出现若干基于 SGX 的原型系统（如用于隐私保护的数据管理、可搜索加密数据库、受信任的数据共享平台等），并在论文中报告了安全性与性能的权衡结果。工程化与产业化尝试：大型厂商（包括 Intel、云服务商以及行业解决方案提供商）开始将机密计算纳入产品路线，例如提供基于 TEE 的机密计算服务、行业 POC（医疗数据共享、AI 模型训练）等，推动技术向可用性、标准化与合规方向发展。[12]

国内研究现状：

研究热度快速上升：国内高校与科研机构近年在 TEE/机密计算方向投入较多精力，产生了大量学位论文与期刊论文，研究主题涵盖 SGX 安全性、密态数据库设计、远程证明、Sealing 与密钥管理等。结合国家合规与行业需求的应用研究：国内研究更侧重于面向法规合规（如《个人信息保护法》）和行业应用（如医疗信息共享、基因数据处理）的系统设计与实现，强调可审计性、权限管理与数据可控共享策略。性能优化与工程问题：考虑到现实部署中对延迟和吞吐的要求，国内研究也在关注 SGX 的调用开销、Switchless 等优化手段，以及在边缘 / 云协同下的资源调度问题。政策与产业推动：政府与企业推动下，机密计算与可信硬件在医疗、金融等领域的试点与产业方案逐步增多，推动学术成果向工程实现转化。

意义：

本项目旨在利用 Intel SGX 技术，构建一个“密态”病历信息系统。其核心意义在于，将所有涉及病历数据的敏感操作（如解密、查询、修改、存储）全部置于 SGX Enclave 内部执行。[6]

理论意义：

实现“全生命周期”数据保护：填补了传统加密技术在“使用中”环节的安全空白，实现了数据从

存储、传输到处理的全生命周期密态保护。革新信任根：将系统的信任根从庞大且易受攻击的操作系统/VMM，缩小到仅几百 KB 的 Enclave 代码和可信的 CPU 硬件，极大减少了攻击面。

现实意义：

保障患者隐私：从根本上杜绝了因服务器被黑、管理员恶意操作、系统漏洞导致的核心病历数据泄露风险，强力保障患者隐私。满足合规需求：随着《网络安全法》、《数据安全法》以及《个人信息保护法》（PIPL）等法规的日趋严格，本系统提供了一种强有力的技术手段，帮助医疗机构满足数据安全与隐私保护的合规要求提升医患信任：为患者提供“数据可用不可见”的安全承诺，增强患者对医疗信息系统的信任度，有助于推动远程医疗、医疗大数据等新兴业态的发展。

相关技术：为了解决“使用中”数据的保护难题，可信执行环境（Trusted Execution Environment, TEE）技术应运而生。TEE 是一种基于硬件的安全解决方案，它在主处理器内部创建一个隔离的安全区域，通常被称为“飞地”（Enclave）。Intel Software Guard Extensions (Intel SGX) 是目前业界最具代表性的 TEE 实现之一。SGX 允许应用程序在内存中划分出一块被称为 Enclave 的区域。这块区域受到 CPU 硬件的强制保护，其内部的代码和数据对外部环境（包括操作系统、驱动程序、BIOS 甚至物理探针）都是加密和隔离的。即便是拥有最高权限的管理员或操作系统内核，也无法读取或篡改 Enclave 内部的明文数据。

二、研究的基本内容与拟解决的主要问题：

本系统的研究内容和目标是构建一个基于 Intel SGX 的安全病历管理系统，实现从用户认证到数据操作的全程密态处理，确保即使系统被攻破，病历明文数据也不会泄露。

2.1 研究的基本内容

2.1.1 多用户身份定义与安全认证管理

角色模型设计：系统设计了三类权限明确的角色。患者拥有对自己基本信息的读写权和对自已病历的只读权；医生拥有对患者基本信息的只读权和对病历的读写权；管理员仅负责持有 SGX 硬件环境和系统的初始化部署，无法接触任何业务数据。基于非对称加密的身份认证：研究并在 Enclave 内部实现基于 RSA 或 ECC 算法的公钥认证体系。管理员对用户身份进行离线核验后，用户在本地生成密钥对，将公钥通过安全通道注册至 Enclave 内部的白名单中。登录时，Enclave 通过验证用户签名的挑战值（Challenge-Response）来完成身份认证，全程杜绝口令明文传输。

2.1.2 患者基本信息的 Enclave 内密态管理

安全数据结构设计：在 Enclave 内存空间中设计专门的数据结构（如 C++ STL Map 或自定义安全链表）来暂存解密后的患者基本信息（姓名、身份证号、联系方式等）。细粒度访问控制（RBAC）：在 Enclave 内部编写可信逻辑，强制执行访问控制策略。例如，当收到“修改信息”请求时，Enclave 会首先校验发起者的数字签名是否属于“患者本人”，只有验证通过才允许执行写操作，否则直接拒绝，从而防止越权访问。

2.1.3 患者病历信息的全生命周期密态处理 [3]

密态 CRUD 逻辑：实现病历信息（诊断记录、处方、检查报告）的增删改查逻辑。所有操作均通过加密的 ECall 接口传入，数据仅在 CPU 内部的 Enclave 隔离区解密为明文进行处理，处理完成后立即在 Enclave 内重新加密输出，确保明文数据“不落地”。数据完整性保护：为了防止外部攻击者恶意篡改或重放旧数据，系统将在密文数据中引入完整性校验码（MAC）或版本号机制，Enclave 在读取数据时会自动校验数据的完整性和新鲜度。

2.1.4 基于 Switchless 的高频交互性能优化 [11]

针对 SGX 传统的 ECall/OCall 上下文切换开销大的问题，深入研究 Intel SGX SDK 提供的 Switchless（无切换）模式。通过在非安全区和安全区之间构建共享内存环形缓冲区，利用工作线程轮询机制替代传统的 CPU 模式切换，从而显著降低高频数据访问时的系统延迟，提升系统整体吞吐量。

2.2 拟解决的主要问题

2.2.1 密态环境下的系统安全性构建与密钥保护 [1]

可信关系的建立：解决如何让远程的医生和患者确信他们连接的服务器是真实的 SGX 环境而非恶意模拟器。这需要实现 SGX 远程证明（Remote Attestation）流程，验证 Enclave 的签名（MRENCLAVE）和签名者（MRSIGNER）。数据持久化的安全性（Sealing）：解决内存数据在断电或重启后的安全存储问题。需要利用 SGX 独有的 Sealing（密封）机制，使用硬件根密钥派生的密封密钥（Seal Key）对数据进行加密和完整性封存，确保只有原本的 Enclave 实例才能解密读取存储在磁盘上的文件，防止离线攻击。密钥安全管理：解决如何在 Enclave 内部安全地生成、分发和更新会话密钥与数据密钥，确保密钥全生命周期不出 Enclave。

2.2.2 可信执行环境下的性能瓶颈与优化 [11]

上下文切换开销：SGX 的安全隔离机制导致 ECall/OCall 的调用成本远高于普通函数调用（约高出数千个时钟周期）。在病历查询等高频交互场景下，这会成为严重的性能瓶颈。优化策略的实现：解决如何正确配置和集成 Switchless 模式，平衡 CPU 资源占用与响应延迟，使“密态系统”达到接近原生系统的可用性。

三、研究的方法与技术路线：

研究方法

1. 文献分析法：深入学习《任务书》指定的参考文献，以及 Intel SGX 官方开发文档、学术论文（如 OSDI 上的相关文章），全面了解 TEE 原理、SGX 编程模型、远程证明机制以及密态数据库的主流实现方案。
2. 原型迭代法：采用敏捷开发思想。首先，搭建环境并跑通官方的 "Hello World" 示例；然后，实现基础的 Enclave 内密钥生成与加解密功能；接着，逐步实现用户管理、病历管理等业务逻辑；最后，进行性能优化和安全加固。
3. 实验测试法：针对系统的核心功能（如认证、密态增删改查）设计测试用例；针对性能优化（Switch-less 模式）设计对比实验，测量优化前后的 ECall 延迟和系统吞吐量。
4. 技术路线本系统将采用 C/S 架构，基于 Intel SGX SDK，使用 C/C++ 语言在 Linux (Ubuntu) 平台进行开发。

客户端（医患）：运行于远程设备，负责界面交互、数据加密和签名。

服务端（不可信 App）：运行于管理员服务器，充当“中转站”。它负责网络通信、管理 Enclave 的生命周期、存储 Enclave 输出的加密数据（Opaque Blob），但它无法解密和理解这些数据。

服务端（可信 Enclave）：系统的“安全核心”。它在 CPU 硬件保护下运行，内部包含：

用户公钥库：用于身份认证。

数据加密密钥：用于加密病历数据。

业务逻辑：所有敏感操作（解密请求、验证权限、操作明文数据、加密响应）。

核心工作流程（以“医生添加病历”为例）：

启动与认证：医生客户端启动，首先请求与服务端的 Enclave 建立安全信道（执行远程证明），确保 Enclave 可信。登录：医生使用本地私钥对登录请求进行签名，发送给服务端。

Enclave 验证：服务端 App 通过 ECall 将请求转入 Enclave。Enclave 使用内部存储的医生公钥进行验签，认证通过。业务请求：医生在客户端填写病历，使用（远程证明阶段协商的）会话密钥加密病历内容，发送给服务端。Enclave 处理：服务端 App 再次 ECall 转入 Enclave。Enclave 解密数据，检查医生权限，将明文病历添加到内部数据结构（如安全链表或字典树）中，然后将更新后的数据结构整体用 Enclave 自己的密钥加密。

安全持久化（Sealing）：为了保存最新的病历状态，Enclave 内部调用 SGX 提供的接口。该接口使用硬件派生的密封密钥（Seal Key）对病历数据进行加密和完整性保护，生成一个 Sealed Data Blob。随后，Enclave 通过 OCall 将这个密封的数据块发送给不可信 App，App 将其写入磁盘文件或数据库中。

四、研究的总体安排与进度：

1. 2025 年 10 月：资料收集，查阅文献，了解选题的背景与意义，确定论文的工作方向与路线；
2. 2025 年 11 月：逐步完成文献综述、文献翻译和开题报告；
3. 2025 年 12 月：完成文献综述、文献翻译和开题报告定稿，正式开题，开始进行毕业设计与毕业论文的撰写；
4. 2025 年 1-3 月：撰写毕业论文并逐步完成毕业设计实物；
5. 2025 年 4 月：进行毕业论文的修改与核查，并在 4 月 15 日前完成毕业论文定稿，开始准备毕设答辩；
6. 2025 年 5 月：进行毕设的答辩。

五、主要参考文献：

- [1] 李旖旎. 基于 Intel SGX 的工业互联网平台数据隐私保护机制研究 [J]. 电脑编程技巧与维护, 2024.
- [2] 许书宁. 基于可信执行环境的可搜索加密数据库研究 [D]. 华中科技大学, 2024.
- [3] 罗楚瑶. 基于 SGX 的多方数据安全计算密码模块设计与实现 [D]. 西安电子科技大学, 2024. DOI:10.27389
- [4] 梁子原. 多方场景下的软硬件协同的隐私数据安全技术研究 [D]. 浙江大学, 2023. DOI:10.27461
- [5] 高天. 基于可信执行环境的安全数据存储机制研究 [D]. 南京理工大学, 2023. DOI:10.27241
- [6] 张珑脐. 基于机密计算的隐私数据安全共享模型的研究与实现 [D]. 华南理工大学, 2022.
- [7] 杨光远, 杨大利, 张羽, 等. 基于可信硬件的隐私数据可搜索加密加速方法研究 [J]. 信息安全研究, 2021, 7(04): 319-327.
- [8] 苟旭春. 基于 SGX 的远程程序敏感变量隐藏技术研究 [D]. 西安电子科技大学, 2022.
- [9] 韦衡纳, 郑晓琦. 基于大数据的医疗信息系统平台构建与应用 [J]. 互联网周刊, 2025, (01): 48-50.
- [10] Ahmed F. Blockchain-Driven Privacy and Security Protection in Decentralized Data Sharing Systems[D]. 中国科学技术大学, 2024. DOI:10.27517
- [11] 王烁程. 面向新一代 Intel 可信执行环境的性能优化方案 [D]. 南京大学, 2021. DOI:10.27235
- [12] Will N C, Maziero C A. Intel Software Guard Extensions Applications: A Survey[J]. ACM Computing Surveys, 2023, 55(14s): 1-38.
- [13] Wang Z, Zhou Y. Analysis and Evaluation of Intel Software Guard Extension-Based Trusted Execution Environment Usage in Edge Intelligence and Internet of Things Scenarios[J]. Future Internet, 2025, 17(1): 32.
- [14] Coppolino L, D' Antonio S, Formicola V, et al. VISE: Combining Intel SGX and Homomorphic Encryption for Cloud Industrial Control Systems[J]. IEEE Transactions on Computers, 2020, 70(5): 711-724.
- [15] Zhou C, Barati M. A TEE-Guarded Data Management System for Time-Scale Data in Industrial Internet of Things[J]. IEEE Internet of Things Journal, 2025.
- [16] Zheng W, Wu Y, Wu X, et al. A Survey of Intel SGX and Its Applications[J]. Frontiers of Computer Science, 2021, 15(3): 153808.

ä

指导教师审核意见：

签名： 教师电子签名

2025 年 11 月 25 日